

Care Access Navigator

Risk Management Rubric - Criterion 3: Risk Evaluation Methods

Purpose

This criterion evaluates the risks identified during the earlier risk assessment and determines which risks and critical assets deserve the most attention. It combines business-focused risk scoring, Business Impact Analysis, financial-impact estimates, dependency mapping, stakeholder review, and a critical asset risk exposure register.

The purpose is not to identify new risks from the beginning. Instead, this criterion takes the risks already identified and evaluates them in more detail so that recovery priorities, business impact, and management attention can be justified.

1. Define the Multi-Criteria Evaluation Model

- What:** Evaluate each major risk using four business factors: financial impact, operational impact, compliance impact, and reputation impact.
- How:** Using a 1-5 measurement scale and applying percentage weights to each factor so that the more important business factors are contributing more to the final evaluation score.
- Why:** The likelihood x impact score used in the earlier risk assessment shows overall risk severity. This weighted model adds a business perspective by showing how strongly the risk affects cost, operations, healthcare compliance expectations, and trust.

For this project, Compliance Impact receives the highest starter weight because Care Access Navigator is designed around secure access to simulated electronic Protected Health Information (ePHI). Operational Impact is also important because Identity and Access Management (IAM) failures can prevent legitimate users from accessing connected applications.

Evaluation Factor	Weight	Meaning in Care Access Navigator
Financial Impact	20%	Estimated direct and indirect cost caused by the event, including recovery and investigation effort.
Operational Impact	25%	Effect on user authentication, application availability, security monitoring, or normal access processes.
Compliance Impact	35%	Effect on healthcare security expectations, access governance, auditability, and protection of simulated ePHI.
Reputation Impact	20%	Potential loss of confidence if users, managers, or stakeholders cannot trust access controls or security processes.

Measurement scale: 1 = Very Low, 2 = Low, 3 = Moderate, 4 = High, 5 = Very High.

$$\text{Weighted Score} = (\text{Financial} \times 20\%) + (\text{Operational} \times 25\%) + (\text{Compliance} \times 35\%) + (\text{Reputation} \times 20\%)$$

The weighted score remains on a 1-5 scale. A higher result means the risk has greater overall business significance across the selected evaluation factors.

2. Evaluate the Major Risks

- What:** Apply the weighted model to the major Identity and Access Management (IAM) and cybersecurity risks already identified for Care Access Navigator.
- How:** Giving each risk a 1-5 score for financial, operational, compliance, and reputation impact, multiplying each score by its assigned weight, and adding the results to produce one weighted score for comparison.
- Why:** This creates a consistent and repeatable way to compare risks that may have different types of business impact.

Risk	Financial	Operational	Compliance	Reputation	Weighted Score
R01 Excessive Role-Based Access Control (RBAC) privileges	3	4	5	4	4.15
R02 Terminated account remains active	3	4	5	4	4.15

Risk	Financial	Operational	Compliance	Reputation	Weighted Score
R03 Credential compromise	4	4	5	5	4.55
R04 Privileged account misuse	4	5	5	5	4.80
R05 Expired vendor access	3	3	4	4	3.55

For example, R04 - Privileged account misuse receives the highest starter weighted score because misuse of an administrative account could create a strong operational, compliance, and reputation impact across the environment.

These values are starter scenario-based assessment values. They should be revised when actual configuration, testing, or stakeholder review provides stronger evidence.

3. Perform the Business Impact Analysis (BIA)

What:	Identify the critical assets in the project and determine how long each asset could be unavailable before the disruption becomes unacceptable.
How:	Defining a Recovery Time Objective (RTO), Recovery Point Objective (RPO), Maximum Tolerable Downtime (MTD), and starter financial-impact estimate for each critical asset based on its role in the simulated environment.
Why:	Business Impact Analysis (BIA) helps determine recovery priorities. An asset with a short RTO or MTD should normally receive more urgent recovery attention than an asset that can remain unavailable for a longer period.

Recovery Time Objective (RTO) is the target amount of time within which a service should be restored after disruption. Recovery Point Objective (RPO) represents the maximum acceptable amount of data loss measured in time. Maximum Tolerable Downtime (MTD) is the longest period the organization can tolerate the service being unavailable before the impact becomes unacceptable.

Critical Asset	RTO	RPO	MTD	Starter Financial Impact
Keycloak Identity and Access Management (IAM)	4 hrs	1 hr	8 hrs	\$25,000
Electronic Health Record (EHR) Simulator	4 hrs	2 hrs	8 hrs	\$30,000
Patient Portal	8 hrs	4 hrs	24 hrs	\$15,000
Authentication / Access Logs	8 hrs	1 hr	24 hrs	\$12,000
Governance, Risk, and Compliance (GRC) Evidence Repository	24 hrs	8 hrs	48 hrs	\$8,000

Keycloak IAM and the EHR Simulator have the shortest starter RTO and MTD values because identity services and access to the simulated healthcare application are treated as highly time-sensitive in the project scenario.

The financial figures above are educational scenario estimates for the simulated project and do not represent actual organizational losses.

4. Document the Financial Impact Method

What:	Estimate the monetary effect of a disruption for an important asset.
How:	Combining scenario-based cost categories such as lost productivity, recovery effort, investigation and analyst effort, and potential compliance or business impact into one estimated financial-impact value.
Why:	The rubric requires financial impact analysis as part of the Business Impact Analysis. Showing the cost components makes the estimate easier to understand and justify.

The example below uses a temporary Keycloak IAM outage. The values are not actual costs; they demonstrate how a financial-impact estimate can be built from several categories.

Example - Keycloak IAM outage	Starter Estimate	Explanation
Lost productivity	\$6,000	Estimated time lost while users cannot authenticate normally.
Recovery effort	\$4,000	Estimated technical effort required to restore the identity service.
Investigation / analyst effort	\$5,000	Estimated security and administrative effort to understand the disruption.

Example - Keycloak IAM outage	Starter Estimate	Explanation
Compliance / business impact allowance	\$10,000	Scenario allowance representing broader business and governance impact.
Total estimated impact	\$25,000	Combined starter estimate used for this BIA example.

5. Map Interconnection Dependencies

What:	Show which project components depend on other systems, data, or security processes.
How:	Tracing the path from each source asset to the systems and activities that are depending on it and documenting how one failure could be creating secondary effects across connected components.
Why:	A system can be more critical than it first appears if several other systems depend on it. Dependency mapping helps explain why some assets require shorter recovery targets or stronger controls.

For example, if Keycloak IAM is unavailable, users may be unable to authenticate to the Electronic Health Record Simulator, Patient Portal, Billing application, or Human Resources application. Similarly, if authentication and access logs are unavailable, Security Information and Event Management (SIEM) monitoring and incident investigation become less effective.

Source Asset	Depends On / Affects	Risk Evaluation Meaning
Keycloak IAM	User authentication -> EHR Simulator -> Patient Portal -> Billing App -> Human Resources (HR) App	Failure has broad operational impact because several applications depend on centralized identity services.
Authentication / Access Logs	Security Information and Event Management (SIEM) monitoring -> alert investigation -> incident evidence -> GRC reporting	Logging failure reduces detection, investigation quality, and evidence availability.
Role-Based Access Control (RBAC) / Access Roles	Keycloak roles -> application permissions -> electronic Protected Health Information (ePHI) access	Misconfiguration can propagate excessive or inappropriate access across connected applications.

6. Document Evaluation Criteria and Stakeholder Approval

What:	Record which project roles provide input, review the evaluation method, and make or approve risk-related decisions.
How:	Assigning responsibility for Identity and Access Management information, security analysis, risk scoring, business-impact review, and acceptance of significant residual risk so that each evaluation activity has a clear owner.
Why:	Documented responsibility makes the evaluation process more defensible because the scores and decisions are not presented as arbitrary or ownerless.

The roles below are used as governance roles for the project evaluation. They show who would contribute technical information, validate the scoring approach, review business impact, and approve important risk decisions.

Role	Evaluation Responsibility
Identity and Access Management (IAM) Analyst	Provides information about user accounts, Role-Based Access Control, access controls, and Joiner-Mover-Leaver lifecycle activities.
Security Analyst	Provides threat, monitoring, incident, and operational-impact information.
Governance, Risk, and Compliance (GRC) Analyst	Maintains the scoring method, risk evaluation records, assumptions, and supporting rationale.
Department Manager	Reviews business impact, operational priorities, and proposed treatment decisions.
Program Sponsor	Approves or formally accepts significant residual risk when required.

7. Create the Critical Asset Risk Exposure Register

What:	Summarize the most important assets, threats, vulnerabilities, recovery requirements, and final exposure level in one management-friendly table.
--------------	--

How: Combining the weighted risk evaluation, Business Impact Analysis values, and dependency findings into a single view and recording the resulting exposure level for each critical asset.

Why: This register gives a reviewer a concise view of which assets have the greatest exposure and why they deserve priority.

The exposure level below is a starter project assessment. It brings together the major threat or vulnerability, system dependency, and recovery targets rather than relying on one score alone.

Asset	Main Threat / Vulnerability	Dependency	RTO / RPO / MTD	Exposure
Keycloak IAM	Credential compromise / Multi-Factor Authentication (MFA) or authentication gaps	EHR, Patient Portal, Billing, HR	4h / 1h / 8h	Critical
EHR Simulator	Excessive Role-Based Access Control permissions / unauthorized ePHI access	IAM and logging	4h / 2h / 8h	Critical
Authentication / Access Logs	Insufficient monitoring / missed events	SIEM, incident response, GRC evidence	8h / 1h / 24h	High
Vendor Accounts	Expired access / weak third-party governance	IAM and connected applications	N/A	High
GRC Evidence Repository	Evidence loss / incomplete records	Risk, control, and compliance reporting	24h / 8h / 48h	Moderate

8. Criterion 3 Result

For Criterion 3, Care Access Navigator risks are evaluated using a weighted financial, operational, compliance, and reputation model. Critical assets are then analyzed through Business Impact Analysis using Recovery Time Objective, Recovery Point Objective, Maximum Tolerable Downtime, and financial-impact assumptions. Interconnection dependencies are documented, evaluation responsibilities are assigned, and the results are summarized in a critical asset risk exposure register.

This gives the project a clearer business-focused view of risk. It helps explain not only which risks are serious, but also which systems are most time-sensitive, what other components depend on them, and which exposures should receive priority attention.

Important note: The scores, weights, recovery targets, and financial values in this document are starter assessment values for the simulated project. They should be updated when actual project testing and stakeholder review provide stronger evidence.